

# XYNERA HONEYPOT CODE AUDIT REPORT

Deception Client (hriday/baseline-v3.2) vs. FastAPI Backend



|                       |                                                                                             |
|-----------------------|---------------------------------------------------------------------------------------------|
| Audited Git Branch    | hriday/baseline-v3.2 (GitHub Remote)                                                        |
| AI Backend Reference  | xynera-ai (FastAPI Personalities Engine)                                                    |
| Date of Audit         | July 10, 2026                                                                               |
| Author                | Xynera AI Security Agent (Antigravity)                                                      |
| Evaluation Scope      | Gap analysis of client connection, failovers, dynamic file syncs, and shell prompt identity |
| Classification Status | INTERNAL USE ONLY - Restricted                                                              |

## 1. Executive Summary

A follow-up code audit has been conducted on the newly released **hriday/baseline-v3.2** branch of the **xynera-honey** deception layer. This branch introduces substantial local realism improvements, including a dynamic class-based in-memory filesystem (supporting copy-on-write mutations like mkdir/touch/rm) and a session-specific service manager (service\_manager.py) to track running/stopped ports.

Despite these excellent client-side dynamics, **critical gaps remain** in the integration with the dynamic AI backend (**xynera-ai**). Specifically, the client still lacks a connection to the backend during runtime, uses an un-integrated client stub, blocks concurrent users on a single-threaded loop, and hardcodes prompt/system discovery variables. This creates a severe 'Identity Contradiction' when the backend switches its threat personalities. This report provides a detailed roadmap of updates the cyber team must apply to this branch.

## 2. Required File-Wise Updates (v3.2 Baseline)

The following analysis outlines the specific updates the cyber team must perform in the files of the **hriday/baseline-v3.2** branch:

| File Path                       | Status in v3.2                                                                                           | Required Updates & Action Items                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------------------|----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| xynera-honey/server.py          | <b>Partially Updated:</b> Added prompt tilde formatting (~). Loop is still blocking and single-threaded. | <ul style="list-style-type: none"> <li>• <b>**Enable Concurrency:**</b> Rewrite the listener connection loop to spawn a thread (threading.Thread) for each incoming socket, preventing DOS.</li> <li>• <b>**AI Backend Callbacks:**</b> Import ai_client and intercept command execution. Call send_to_ai as a fallback if the command is not handled locally.</li> <li>• <b>**Dynamic Prompt User/Host:**</b> Replace hardcoded HOSTNAME = 'web-prod-01' and USERNAME = 'ubuntu' with session-level variables updated dynamically from the backend personality response.</li> </ul> |
| xynera-honey/ai_client.py       | <b>Unchanged:</b> Single hardcoded target URL, 335s timeout, dead code.                                  | <ul style="list-style-type: none"> <li>• <b>**Timeout and Routing Failovers:**</b> Reduce timeout to 5.0s and implement failover URLs (127.0.0.1, localhost, remote IP).</li> <li>• <b>**Rich Request Payload:**</b> Update send_to_ai signature to send session_id, cwd, hostname, and username.</li> <li>• <b>**JSON Response Parsing:**</b> Return a dictionary with reply, personality_name, hostname, and username.</li> </ul>                                                                                                                                                  |
| xynera-honey/command_router.py  | <b>Highly Improved:</b> Intercepts dynamic filesystem commands and checks deception engine first.        | <ul style="list-style-type: none"> <li>• <b>**Dynamic System Discovery:**</b> Intercept local commands (whoami, hostname, uname -a, groups, id) and return the active session's persona details instead of hardcoded strings.</li> </ul>                                                                                                                                                                                                                                                                                                                                             |
| xynera-honey/fake_filesystem.py | <b>Fully Rewritten:</b> Dynamic class-based in-memory filesystem with node traversal and tree cloning.   | <ul style="list-style-type: none"> <li>• <b>**Data Syncing:**</b> For target files (like employee_directory.csv), query the backend's session cache during a read request (cat) to serve the AI's randomized credentials.</li> </ul>                                                                                                                                                                                                                                                                                                                                                 |
| xynera-honey/fake_network.py    | <b>Improved:</b> Added shared DNS cache and consistent service port mappings.                            | <ul style="list-style-type: none"> <li>• <b>**Dynamic Host IP:**</b> Replace the hardcoded interface IP 192.168.1.25 in ifconfig with the dynamic local IP resolved from the accepted socket interface.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                   |
| xynera-honey/session_manager.py | <b>Updated:</b> Allocates dynamic filesystem and service managers per session.                           | <ul style="list-style-type: none"> <li>• <b>**Identity Caching:**</b> Store the current session's active hostname and username, allowing them to mutate.</li> <li>• <b>**Backend Threat Sync:**</b> Remove client-side threat scoring calculations; rely on the backend API's response scores as the single source of truth.</li> </ul>                                                                                                                                                                                                                                              |

### 3. AI Backend Personality Alignment Gaps

The new AI backend in personalities.py shifts the server's identity dynamically based on the threat score (Friendly Server, Normal Server, Suspicious Server, High Security Server). This introduces the following integration gaps:

• **The Prompt Identity Mismatch:**

When the AI backend shifts its persona to *High Security Server*, it assumes the identity of root@prod-restricted-01. Any AI-generated responses (e.g. system files, error logs) will assume this environment. However, because the client prompt in server.py is hardcoded to ubuntu@web-prod-01, the attacker is presented with conflicting identities. The prompt must dynamically sync with the backend's active personality data.

• **Local Command Contradictions:**

Local commands handled in command\_router.py (like whoami returning 'ubuntu', hostname returning 'web-prod-01', and uname -a returning 'Linux web-prod-01...') are static on the v3.2 branch. If the AI backend shifts the server's state, local command responses will instantly contradict the AI's persona, raising immediate suspicion.

**API Payload Mismatches (v3.2 vs. FastAPI Backend):**

| Field Name | Client Status (v3.2) | Backend Expects | Impact / Consequence of Absence                                          |
|------------|----------------------|-----------------|--------------------------------------------------------------------------|
| session_id | NOT Sent             | Optional (str)  | Backend cannot correlate command histories; resets threat profiles.      |
| cwd        | NOT Sent             | Optional (str)  | AI replies cannot adapt to the attacker's working directory.             |
| hostname   | NOT Sent             | Optional (str)  | AI cannot align its prompt responses with the client's current hostname. |
| username   | NOT Sent             | Optional (str)  | AI replies cannot change formatting for privileged root sessions.        |

## 4. Recommended Cyber Team Implementation Plan

To achieve a seamless, highly believable deception layer, the cyber team must perform the following integrations on top of the **hriday/baseline-v3.2** branch:

1. **\*\*Integrate AI Client Fallback:\*\*** Modify the connection handler in `server.py` to import `ai_client`. If `route_command` returns a `command-not-found` error, query the AI backend, extract the payload response, and update the session's active prompt variables.
2. **\*\*Dynamic Prompt Rendering:\*\*** In `server.py`, refactor the connection loop to use session-level variables for the user and host, rather than top-level constants. Redraw prompt using `f'{username}@{hostname}:{display_dir}$ '` dynamically.
3. **\*\*Dynamic System Command Mapping:\*\*** Refactor local commands in `command_router.py` (like `whoami`) to fetch values dynamically from the current session's cached attributes instead of hardcoded strings.
4. **\*\*Resolve Single-Thread Blocking:\*\*** Convert the socket server to a multi-threaded TCP server using Python's `socketserver.ThreadingTCPServer`, ensuring concurrent session scalability.
5. **\*\*Sync Filesystem Targets with Backend Cache:\*\*** Intercept read actions (like `cat`) on key files (such as `employee_directory.csv`) inside `fake_filesystem.py`, and query the backend's generated session cache to serve identical records.
6. **\*\*Dynamic Host IP Binding:\*\*** Replace `SERVER_IP = '192.168.1.25'` in `fake_network.py` with a utility that dynamically fetches the actual listening IP address of the honeypot client.